

Eight things only you can decide

The engineering work is done and proven on hardware. What is left is a mailbox, four signatures, a lawyer, and one hour in a room — and this page is only that list, with the reason each one is not optional.

BOUND BY LAW 11 Sep 2026	BOUND BY FIRST SHIPMENT Before unit one	YOUR TIME, IN TOTAL ~3 hours
ENGINEERING OWED None		

01 · THE SHORT VERSION

Why any of this is compulsory

The Cyber Resilience Act is an EU **regulation**. That word matters: it binds directly in every member state, with no national law to wait for and no transition period once a date passes. It applies to us as the *manufacturer* of a product with digital elements, and it applies to units we have already sold as well as to units we ship next.

It carries two dates that concern Joral.

11 Sep 2026	We must be able to report If a weakness in our product is being actively exploited, or a serious security incident happens, we must tell the European authorities within 24 hours of finding out, with fuller detail at 72 hours and a final report inside two weeks. We must tell affected customers too.
------------------------	---

**11 Dec
2027**

Everything else

CE marking, the technical file, the published security policy, and the security properties the product itself must have. Those properties are already built and demonstrated; that date is about paperwork and marking.

The September date is not a target we set. It is a clock, and we do not control what starts it.

Enforcement sits with national market-surveillance authorities, whose powers extend to ordering a product off the market, and the penalties for these particular obligations sit in the regulation's top band. Your counsel should confirm the figure — the point here is only that it is not a fine you absorb as a cost of doing business.

Separately from the regulation, a second deadline runs in parallel: **the first customer unit**. A handful of decisions become permanent the moment one leaves the building, because no software update can reach back and change them. Those are marked below.

02 · YOUR LIST

In the order that costs least

Roughly three hours of your time in total, most of it in one meeting. Two items need somebody else's calendar, so they go first.

1 Ask counsel one question about reporting

REQUIRED BY 11 SEP OWNER: YOU → COUNSEL AN EMAIL

Reports go to the European cybersecurity agency *and* to a national cyber-incident team — which one depends on where the manufacturer is established in the EU, or where its appointed EU representative is. We are a US company, so counsel needs to tell us which team that is for Joral, and whether appointing an EU representative is required or simply sensible.

WHY IT IS FIRST

It is the only item whose length is not ours to decide. Everything else on this page can be done in the week you choose to do it.

2 Create the security mailbox, then publish two files

REQUIRED BY 11 SEP OWNER: YOU OR WHOEVER RUNS WORKSPACE
UNDER AN HOUR

A shared mailbox at security@joralllc.com — a group with at least two people in it, never one person's inbox. Then two short files go on joralllc.com; they are written, checked and waiting, and it is a web upload rather than a project.

In that order. Someone who writes to a published address and hears nothing concludes we do not answer, and what they usually do next is publish the weakness instead of reporting it.

WHY IT IS COMPULSORY

The published channel itself is a 2027 requirement. It has to work by September because of the 24-hour clock: the ordinary way a manufacturer first learns that a weakness is being exploited is that somebody writes in. A clock we cannot hear start is a clock we miss.

3 Name who answers it, and who covers them

REQUIRED BY 11 SEP OWNER: YOU A DECISION

Two names: who reads that mailbox on a working day, and who covers holidays and absence. Give them standing authority to file the 24-hour notice **without waiting for you** — that first notice commits Joral to no finding, it only says we are aware and looking.

WHY IT IS COMPULSORY

The regulation sets the clock and is silent on who runs it. A 24-hour obligation with no named person is the most common way a company misses one.

4 Sign the firmware signing policy

BLOCKS FIRST SHIPMENT OWNER: YOU A SIGNATURE

Our units accept a firmware update only if it is properly signed. That works and has been proven on real hardware. But today it is signed with a temporary development key that lives on a working computer, and a unit that trusts that key is a unit whose update path we cannot vouch for. The policy that fixes it is drafted, recommended, and waiting for your name.

WHY IT IS COMPULSORY

The regulation requires that security updates reach the product securely. That is met by the mechanism — and undone by where the key lives.

5 Confirm the support period: five years

REQUIRED — AND BLOCKS FIRST SHIPMENT OWNER: YOU

SAME SIGNATURE

We must state publicly how long we will provide security updates. The recommendation is five years from the date each model first goes on sale, with the end date printed. Five is the floor for industrial equipment; ten would not be honest today, because parts of the software foundation we build on are supported by their own makers for less than that. Extending later is always allowed. Shortening is a breach.

WHY IT BLOCKS SHIPMENT

The clock starts with the first customer unit, and the manual that ships with it is supposed to name the end date. A number nobody has agreed cannot be printed.

6 Give an hour to the key ceremony

BLOCKS FIRST SHIPMENT OWNER: YOU, WITH YOUR ENGINEER
~1 HOUR, ONCE

The practical follow-up to item 4, and the only item on this page that needs you in a room rather than at a keyboard. Section 03 explains what happens and why it is shaped that way.

WHY IT CANNOT WAIT

What a unit trusts is fixed when it is built. Changing it afterwards means physical access to every unit in the field.

7 Send the customer agreement to counsel

NOT THE REGULATION — BLOCKS FIRST SHIPMENT
OWNER: YOU → COUNSEL THEIR CALENDAR

Three small things in one instruction: counsel reviews the end-user agreement, fills in the one blank in it (which country's law governs), and we decide how a customer actually receives it — today it exists only in our source, and neither manual has a legal section. Send it after item 5, so they are not reviewing a document with the support period left blank.

WHY IT IS A ONE-WAY DOOR

Terms that have gone out with a product cannot be withdrawn from that product. The licence position was still adjustable in August for one reason only: nothing had shipped.

8 Confirm support@joralllc.com exists

BLOCKS SHIPPING THE DOCUMENTS OWNER: YOU MINUTES

The customer agreement and the manuals point customers at that address. Nobody has checked that it is real. Same session as item 2 — there is no reason to do the two mailboxes on different days.

WHY IT MATTERS

A document that advertises an address nobody reads turns a customer trying to do the right thing into a customer being ignored.

There are also two small product questions waiting on you — whether the security log should be sent to a central collector, and whether the system should refuse an obviously nonsensical sensor setting. Neither is compulsory and neither blocks anything; both are quick to build once you have a preference.

03 • THE CEREMONY

The hour, and why it is shaped like that

Every unit we ship will check a signature before it installs firmware. The key that makes those signatures is therefore the most valuable thing Joral will own:

Whoever holds that key can put software on every unit we ever ship.

Which is why it is not created on a build server, or kept in a password manager, or held by one person. Four ideas shape the hour, and each one answers a specific way this goes wrong elsewhere:

- **It is made on a computer with no network, ever.** A key that has never touched a connected machine cannot be taken from one. The laptop runs a temporary system that leaves nothing behind when it is switched off.
- **Two keys are made, not one.** One is used; one is a spare that signs nothing. Both are trusted by every unit from the first one built. If the working key is ever compromised, we switch to the spare with an ordinary update — instead of recalling hardware, which is the alternative and is not really an alternative.
- **Two people, and both hold the passphrase.** Neither of you can act alone, and neither of you leaving strands the company.
- **Four copies, in two buildings.** One set in the office safe, one off-site. Losing a copy is an inconvenience; losing every copy would mean we could never update a fielded unit again.

What actually happens, and what is yours



I bring and run

- A prepared start-up USB and the ceremony script, checked in advance
- The four storage devices, ready to use
- The commands themselves, on your workstation — nothing is installed on it, nothing is left behind, and it is disconnected from the network for the duration
- The paperwork afterwards: the certificates go into the build, and every unit from then on trusts them

Yours, in the room

- Be present for the whole hour — the procedure requires two people and you are one of them
- Choose the passphrase with me, and remember it; it is never written into any system
- Take custody of the two sets afterwards: safe and off-site, the same day
- Sign the one-page record: the date, who was present, and which devices hold what

The signed record is not a formality. When an assessor asks how Joral controls the ability to install software on its products, that sheet of paper is the answer, and it is the kind of evidence that is very hard to produce after the fact.

AFTERWARDS

Signing a release takes about fifteen minutes and involves one of the storage devices coming out of the safe, being used on a disconnected laptop, and going back. It is not a burden on your week; it is the one moment per release where the key is in use, deliberately kept slow and physical.

What you are not being asked for

So the list above reads as complete rather than as the first instalment.

- **The product itself is done.** All eight security properties the regulation requires of the product are implemented, and each has been demonstrated on real hardware rather than in a test suite: secure settings out of the box, no known unfixed vulnerabilities at shipment, protected passwords and configuration, a stripped-down attack surface, access control, a security log, signed updates, and factory reset.
- **The evidence is being kept as we go.** Every release carries a list of the software inside it, checked against public vulnerability databases, and archived. That is what lets us answer “which units are affected?” within the first hour of a report instead of the first week.

- **The remaining engineering is scheduled and blocks nothing** — a test needing equipment we do not have here, two short bench checks, and the first full run of the automated attack-input testing that now runs nightly.
 - **CE marking and the declaration of conformity** are yours and counsel's, on the 2027 timeline, and they are not on this page because nothing about them is due yet. Engineering's job is that every fact those documents rest on is true and provable, and that part is done and evidenced.
-

How it fits in a fortnight

TODAY	Two emails. The reporting question to counsel, and the request to create the two mailboxes. Both are short, and both start clocks that are not yours.
THIS WEEK	One meeting. Sign the signing policy, confirm five years, name the two people who cover the mailbox, and send the customer agreement to counsel. That meeting is items 3, 4, 5 and 7.
SAME WEEK	The ceremony — an hour, on your workstation, whenever suits you after the signature.
BY 9 SEP	A dry run of a report, so that the first time we walk that path is not the first real one. Half an hour, and I will set it up.
11 SEP 2026	The obligation begins. Nothing should happen that day. That is the objective.

Dates and obligations here follow the European Commission's guidance on the Act's reporting obligations. The size of the penalties, which national team receives our reports, and whether Joral needs an appointed EU representative are counsel's to confirm rather than mine to state.